

(a) Modelo de encuesta integral sobre CVSS 4.0 y gestión de vulnerabilidades en España

Versión: 1.0

Ámbito: Empresas y entidades públicas en España

Público objetivo: CISO, CIO, CTO, responsables de seguridad, riesgo, continuidad y cumplimiento

1. Información general de la organización

1.1. Tipo de organización

- ☐ Empresa privada
- ☐ Entidad pública (AGE, CCAA, EELL)
- ☐ Empresa pública / mixta
- ☐ Organización sin ánimo de lucro
- ☐ Otro (especificar): ____

1.2. Sector principal de actividad

- ☐ Energía / Utilities
- ☐ Transporte y logística
- ☐ Finanzas / Seguros
- ☐ Sanidad
- ☐ Industria / Manufactura
- ☐ TIC / Telco
- ☐ Administración pública
- ☐ Educación / Investigación
- ☐ Comercio / Retail
- ☐ Servicios profesionales
- ☐ Otros (especificar): ____

1.3. Tamaño de la organización (empleados)

- ☐ 1 – 49
- ☐ 50 – 249
- ☐ 250 – 999
- ☐ 1.000 – 4.999
- ☐ 5.000 – 19.999
- ☐ ≥ 20.000

1.4. Alcance geográfico de la actividad

- ☐ Local / Regional
- ☐ Nacional
- ☐ Multinacional con sede en España
- ☐ Multinacional sin sede en España (pero con operaciones relevantes)

1.5. Rol del encuestado

- ☐ CISO / Responsable global de ciberseguridad
- ☐ CIO / CTO
- ☐ Responsable de continuidad de negocio / resiliencia
- ☐ Responsable de riesgos / cumplimiento / auditoría
- ☐ Responsable de sistemas / infraestructuras
- ☐ Otro (especificar): ____

2. Madurez general en gestión de vulnerabilidades

2.1. ¿Dispone su organización de un proceso formal y documentado de gestión de vulnerabilidades?

- ☐ Sí, plenamente formalizado, revisado y aprobado por la alta dirección
- ☐ Sí, formalizado pero con aplicación parcial o desigual
- ☐ En fase de definición / piloto
- ☐ No, se actúa de forma reactiva y ad hoc
- ☐ No existe ningún proceso específico

2.2. ¿Con qué frecuencia se realizan actividades de identificación de vulnerabilidades (escaneos, revisiones, etc.)?

- ☐ Continuamente o casi en tiempo real
- ☐ Semanalmente
- ☐ Mensualmente
- ☐ Trimestralmente
- ☐ Menos de una vez al trimestre
- ☐ Solo tras incidentes o auditorías

2.3. ¿Qué fuentes principales utiliza su organización para conocer nuevas vulnerabilidades? (marque todas las que apliquen)

- ☐ NVD / bases de datos de vulnerabilidades internacionales[web:53]
- ☐ INCIBE-CERT / CCN-CERT / otros CERT nacionales[web:63]
- ☐ Boletines de fabricantes y proveedores
- ☐ Herramientas automatizadas de gestión de vulnerabilidades[web:58]
- ☐ Informes de terceros (SOC, MSSP, etc.)
- ☐ Comunidades técnicas y foros profesionales
- ☐ Otras (especificar): ____

2.4. En una escala de 1 a 5, ¿cómo valoraría la madurez global del programa de gestión de vulnerabilidades de su organización?

- ☐ 1 – Muy incipiente
- ☐ 2 – Básico
- ☐ 3 – Intermedio
- ☐ 4 – Avanzado
- ☐ 5 – Líder / referente

3. Uso de CVSS

3.1. ¿Utiliza su organización el framework CVSS para valorar vulnerabilidades?

- ☐ Sí, de forma sistemática en toda la organización
- ☐ Sí, pero solo en determinados ámbitos o tecnologías
- ☐ Se utiliza de manera informal / no homogénea
- ☐ No, pero está previsto adoptarlo en los próximos 12 meses
- ☐ No, ni se utiliza ni se prevé adoptarlo

3.2. ¿Qué versión o versiones de CVSS utiliza actualmente su organización? (marque todas las que apliquen)

- ☐ CVSS v2.x
- ☐ CVSS v3.0
- ☐ CVSS v3.1[web:53]
- ☐ CVSS v4.0[web:16][web:55]
- ☐ No se conoce / no se especifica
- ☐ No se utiliza CVSS

3.3. ¿Cuál de las siguientes afirmaciones describe mejor cómo se utiliza CVSS en su organización?

- ☐ Se toma directamente el score publicado por fabricantes o bases de datos externas[web:53]
- ☐ Se recalculan scores CVSS internamente para los activos más críticos[web:17]
- ☐ Se redefine el vector CVSS para adaptarlo al contexto de la organización[web:17]
- ☐ Se usan scores CVSS solo como referencia orientativa
- ☐ No se realiza ningún cálculo ni ajuste de CVSS

3.4. ¿Quién es el principal responsable de la definición y uso de CVSS en su organización?

- ☐ Equipo de ciberseguridad / SOC interno
- ☐ Proveedor de servicios gestionados (MSSP, SOC externalizado)
- ☐ Equipo de infraestructuras / sistemas
- ☐ Equipo de desarrollo / DevSecOps
- ☐ Equipo de riesgo / cumplimiento / auditoría
- ☐ No hay un responsable claro
- ☐ Otro (especificar): ____

4. Adopción de CVSS 4.0 y métricas Base

4.1. ¿Conoce usted la existencia de CVSS v4.0 y sus diferencias respecto a versiones anteriores?

- ☐ Sí, en detalle
- ☐ Sí, de forma general
- ☐ He oído hablar de ello, pero sin profundidad
- ☐ No, es la primera vez que lo oigo

4.2. ¿En qué grado ha adoptado su organización CVSS v4.0?

- ☐ Totalmente adoptado como estándar principal
- ☐ Parcialmente adoptado (convive con CVSS 3.1 u otros enfoques)[web:53]

- ☐ En evaluación / piloto
- ☐ No adoptado ni previsto
- ☐ No aplica / no se utiliza CVSS

4.3. En relación con las métricas Base de CVSS 4.0 (Attack Vector, Attack Complexity, Attack Requirements, Privileges Required, User Interaction, impactos en C/I/D), indique cuál es la práctica habitual:[web:16][web:58]

- ☐ Se documentan y revisan todas las métricas Base para las vulnerabilidades clave
- ☐ Se revisan solo cuando el resultado publicado genera dudas
- ☐ Se asumen sin revisión las métricas Base publicadas externamente
- ☐ No se trabaja a nivel de métricas Base; solo se usa el número final
- ☐ No aplica / no se usa CVSS 4.0

4.4. ¿Con qué frecuencia se recalculan internamente las métricas Base para vulnerabilidades que afectan a activos críticos?

- ☐ Siempre que la vulnerabilidad afecte a un activo crítico
- ☐ Solo para vulnerabilidades potencialmente críticas (según criterio experto)
- ☐ De forma excepcional, cuando hay discrepancias claras
- ☐ Nunca se recalculan
- ☐ No aplica / no se usa CVSS

5. Métricas Threat y explotación real

5.1. ¿Integra su organización en la priorización la información sobre si una vulnerabilidad está siendo explotada activamente (Threat / Exploit Maturity)?[web:16][web:17]

- ☐ Sí, es un factor clave en la priorización
- ☐ Sí, pero con un peso limitado frente al score Base
- ☐ Solo se tiene en cuenta para vulnerabilidades extremadamente críticas
- ☐ No se incorpora de forma sistemática
- ☐ No se dispone de esa información

5.2. Cuando una vulnerabilidad pasa a tener estado “explotada activamente” según fuentes fiables (CERT, NVD, fabricantes, etc.), ¿cómo reacciona su organización?[web:56][web:61]

- ☐ Se activa un proceso acelerado de evaluación y parcheo (SLA reducido)
- ☐ Se revisa la prioridad de parcheo, pero sin cambios formales de SLA
- ☐ Depende del área / responsable, sin criterio homogéneo
- ☐ No hay un procedimiento específico
- ☐ No se monitoriza este tipo de cambios

5.3. ¿Con qué fuentes de inteligencia se alimentan las métricas Threat o equivalentes? (marque todas las que apliquen)

- ☐ INCIBE-CERT / CCN-CERT / ENISA[web:63]
- ☐ NVD, CISA, otros CERT internacionales[web:53]
- ☐ Proveedores de threat intelligence comerciales

- ☐ Comunidades de intercambio sectoriales (ISAC, asociaciones, etc.)
- ☐ Observación interna de incidentes
- ☐ No se utiliza información específica sobre Threat

6. Métricas Environmental y criticidad local

6.1. ¿Utiliza su organización las métricas Environmental de CVSS para ajustar el score a su contexto?

[web:16][web:17]

- ☐ Sí, de forma sistemática en todos los activos críticos
- ☐ Sí, pero solo en proyectos o sistemas concretos
- ☐ En evaluación / pruebas piloto
- ☐ No, nos limitamos a los scores Base
- ☐ No aplica / no usamos CVSS

6.2. ¿Qué factores se tienen en cuenta al ajustar las métricas Environmental? (marque todas las que apliquen)[web:17][web:63]

- ☐ Tipo de activo (infraestructura crítica, OT, cloud, etc.)
- ☐ Datos tratados (personales, financieros, clasificados, etc.)
- ☐ Impacto en continuidad de negocio
- ☐ Obligaciones regulatorias (NIS2, CRA, DORA, sectoriales, etc.)[web:56][web:57][web:61]
- ☐ Relevancia en la cadena de suministro
- ☐ Otros (especificar): ____
- ☐ No se ajustan las métricas Environmental

6.3. ¿Existe una taxonomía interna de criticidad de activos alineada con los ajustes Environmental?

- ☐ Sí, formalizada y usada en toda la organización
- ☐ Sí, pero solo en determinadas áreas o tecnologías
- ☐ En diseño / revisión
- ☐ No, cada área decide su criticidad de forma independiente
- ☐ No existe ninguna taxonomía de criticidad

7. Métricas Supplemental (Automatable, Safety, Recovery, etc.)

7.1. ¿Conoce su organización la existencia de las métricas Supplemental de CVSS 4.0 (Automatable, Safety, Recovery, Value Density, etc.)?[web:16][web:55][web:58]

- ☐ Sí, y se utilizan activamente
- ☐ Sí, pero aún no se usan de forma sistemática
- ☐ Se conocen de manera superficial
- ☐ No, son completas desconocidas

7.2. ¿En qué medida se tiene en cuenta la automatización potencial de los ataques (Automatable) en la priorización de vulnerabilidades?

- ☐ Es un criterio explícito y cuantificado en el proceso de priorización
- ☐ Se considera cualitativamente en los análisis, pero sin métrica formal

- ☐ Solo se considera para vulnerabilidades singulares “muy mediáticas”
- ☐ No se considera

7.3. ¿En qué medida se tienen en cuenta los impactos en la seguridad física de las personas (Safety) al evaluar vulnerabilidades en sistemas OT, IoT, vehículos, sanitarios, etc.?

- ☐ Está integrado en la metodología de análisis de vulnerabilidades
- ☐ Se considera solo en proyectos específicos de OT/ICS
- ☐ Se aborda caso a caso, sin método definido
- ☐ No se contempla de forma explícita

7.4. ¿Cómo valora la atención de su organización al esfuerzo de recuperación (Recovery) asociado a vulnerabilidades críticas?

- ☐ Se cuantifica (tiempo, recursos, costes) y se incorpora a la priorización
- ☐ Se discute cualitativamente en comités de cambio / riesgo
- ☐ Se asume como “daño colateral” sin medición específica
- ☐ No se tiene en cuenta

7.5. ¿Se considera de alguna manera el “Value Density” (valor concentrado por activo o sistema afectado) al ponderar vulnerabilidades?

- ☐ Sí, es un parámetro explícito (por ejemplo, número de clientes / transacciones por sistema)
- ☐ Sí, pero de forma cualitativa
- ☐ Solo se considera en sistemas muy concretos
- ☐ No se considera

8. Integración con marcos normativos (NIS2, CRA, etc.)

8.1. ¿Está su organización sujeta a NIS2 (directamente o por cadena de suministro)?[web:56][web:61][web:64]

- ☐ Sí, como entidad esencial
- ☐ Sí, como entidad importante
- ☐ Sí, a través de obligaciones contractuales con terceros
- ☐ No
- ☐ No lo sé / no está claro

8.2. ¿Utiliza su organización las métricas CVSS (3.x o 4.0) para demostrar cumplimiento de requisitos de gestión de vulnerabilidades y riesgo exigidos por NIS2?

- ☐ Sí, de forma explícita y documentada en políticas y evidencias
- ☐ Sí, pero de forma indirecta (por ejemplo, como parte de informes técnicos)
- ☐ No, pero se está valorando
- ☐ No, no se utiliza CVSS con fines de cumplimiento normativo

8.3. En el caso de fabricantes de productos con elementos digitales, ¿se utiliza CVSS como parte del proceso de “vulnerability handling” requerido por el Cyber Resilience Act (CRA)?[web:57][web:59][web:62]

- ☐ Sí, como métrica central para clasificar y priorizar vulnerabilidades
- ☐ Sí, pero solo como referencia entre otros criterios
- ☐ No, pero se está valorando
- ☐ No aplica (no desarrollamos productos con elementos digitales)
- ☐ No, ni está previsto

8.4. ¿Dispone su organización de procedimientos documentados de “vulnerability handling” y “coordinated vulnerability disclosure” alineados con la normativa europea? [web:56][web:57][web:62]

- ☐ Sí, formales y probados
- ☐ Sí, pero nunca han sido puestos a prueba en un caso real
- ☐ En diseño / aprobación
- ☐ No, pero se reconoce la necesidad
- ☐ No, y no existe plan definido

9. Indicadores de gestión (IGM) y métricas de desempeño

9.1. ¿Qué indicadores cuantitativos utiliza su organización para medir la eficacia de la gestión de vulnerabilidades? (marque todas las que apliquen)

- ☐ Tiempo medio de parcheo por rango CVSS (por ejemplo, $\geq 9,0$) [web:17][web:63]
- ☐ Número de vulnerabilidades abiertas por rango CVSS y por activo crítico
- ☐ Porcentaje de activos críticos cubiertos por escaneos periódicos
- ☐ Porcentaje de vulnerabilidades críticas mitigadas dentro del SLA interno
- ☐ Número de incidentes vinculados a vulnerabilidades conocidas no corregidas
- ☐ Otros (especificar): ____
- ☐ No se utilizan indicadores cuantitativos

9.2. ¿Existen objetivos formales (KPI/KRI) aprobados por la dirección relacionados con CVSS (por ejemplo, “ninguna vulnerabilidad CVSS-B ≥ 9 sin plan de tratamiento en 7 días”)?

- ☐ Sí, claros y medidos regularmente
- ☐ Sí, pero su seguimiento es irregular
- ☐ Se están definiendo
- ☐ No existen objetivos formales

9.3. ¿Con qué frecuencia se reportan estos indicadores a la alta dirección o al consejo?

- ☐ Mensualmente
- ☐ Trimestralmente
- ☐ Semestralmente
- ☐ Anualmente
- ☐ Solo tras incidentes graves
- ☐ No se reportan

10. ROI de la gestión de vulnerabilidades y percepción de valor

10.1. ¿Considera que la inversión en gestión de vulnerabilidades (herramientas, personas, procesos) está adecuadamente respaldada por la dirección?

- ☐ Sí, plenamente (incluso en años austeros)
- ☐ Sí, en general, con tensiones puntuales
- ☐ Parcialmente; hay una brecha evidente entre riesgo y presupuesto
- ☐ No, la inversión es claramente insuficiente
- ☐ No se dispone de visibilidad suficiente

10.2. ¿Dispone su organización de algún modelo para estimar el retorno de la inversión (ROI) en gestión de vulnerabilidades (por reducción de incidentes, pérdidas evitadas, etc.)?

- ☐ Sí, cuantitativo y documentado
- ☐ Sí, pero principalmente cualitativo
- ☐ En desarrollo / piloto
- ☐ No, aunque se reconoce su utilidad
- ☐ No, y no se considera una prioridad

10.3. ¿Cómo percibe la organización (negocio / áreas usuarias) el valor de la gestión de vulnerabilidades basada en CVSS?

- ☐ Como un habilitador claro de continuidad y confianza
- ☐ Como un requisito regulatorio necesario pero poco “sexy”
- ☐ Como un coste inevitable al que se intenta dedicar lo mínimo
- ☐ Con cierta incompreensión o resistencia
- ☐ No hay una percepción clara

11. Perspectiva estratégica y de futuro

11.1. ¿Qué prioridad tiene, en la agenda estratégica de su organización, la mejora de la gestión de vulnerabilidades y el uso avanzado de CVSS (4.0, métricas Environmental y Supplemental, etc.) en los próximos 2-3 años?

- ☐ Muy alta: proyecto estratégico con patrocinio ejecutivo
- ☐ Alta: prioridad clara, con recursos asignados
- ☐ Media: importante, pero compitiendo con otras urgencias
- ☐ Baja: se aborda solo si “sobra” tiempo o presupuesto
- ☐ No se considera prioritario

11.2. ¿Qué barreras principales percibe para avanzar hacia un uso más maduro de CVSS 4.0? (marque hasta tres)

- ☐ Falta de conocimiento interno especializado[web:58][web:63]
- ☐ Complejidad percibida del modelo (especialmente métricas Environmental y Supplemental)
- ☐ Limitaciones de las herramientas actuales
- ☐ Falta de datos de contexto (inventario de activos, criticidad, dependencias)
- ☐ Falta de apoyo de la dirección
- ☐ Falta de alineamiento con otras áreas (riesgos, negocio, operaciones)
- ☐ Otras (especificar): ____

11.3. ¿Qué palancas considera más eficaces para mejorar el uso de CVSS y la gestión de vulnerabilidades en su organización? (marque hasta tres)

- ☐ Formación especializada (CVSS 4.0, threat intelligence, etc.)[web:58][web:63]
- ☐ Mejoras de herramientas y automatización
- ☐ Clarificación de responsabilidades y gobierno
- ☐ Integración con métricas de riesgo empresarial
- ☐ Impulso regulatorio y de supervisores
- ☐ Programas de concienciación dirigidos a la alta dirección
- ☐ Otros (especificar): ____

12. Comentarios finales

12.1. Si quiere compartir alguna reflexión irónica, constructiva o simplemente terapéutica sobre CVSS, la gestión de vulnerabilidades y la realidad del día a día, este es su espacio:

Gracias por su participación.

Su experiencia y honestidad son, en sí mismas, un excelente indicador de madurez.